Supplier and subcontractor security policy

Risk tiers

Every supplier is assigned to one of three risk tiers before the contract is signed. Tier 1 covers suppliers that process customer data or have access to production; Tier 2 covers suppliers with access to internal systems only; Tier 3 covers all others.

Due diligence

Tier 1 suppliers complete a security questionnaire and provide evidence of controls, such as a valid ISO/IEC 27001 certificate. A data processing agreement and a non-disclosure agreement are mandatory for Tier 1 and Tier 2. The right to audit is included in the contracts with Tier 1 suppliers.

Ongoing monitoring

Tier 1 suppliers are reviewed every year; Tier 2 suppliers every two years. Security incidents on the supplier side must be reported to the company within 24 hours after the supplier becomes aware of them.

Subprocessors

Customers whose data is processed by a subprocessor are informed in writing at least 30 days before a subprocessor is added or replaced. A customer may object within this period. The current list of subprocessors is provided to a customer on request.